



Workshop: Building Your AI Risk Policy

AI Risk Management Section — Workshop Lesson





Workshop Objectives

By the end of this workshop, you will be able to:

1

Build from Scratch

Walk through building an AI risk policy from the ground up, step by step

2

Practical Examples

See real-world examples for each section of the policy

3

Real-World Challenges

Learn how to handle Shadow AI, vendor tools, and compliance mapping

4

Working Draft

Leave with a working draft you can adapt to your own organization



Meet Northwind Financial Services

Throughout this workshop, we will follow a fictional company building its first AI risk policy.

~800 Employees

Mid-size US regional bank

Heavily Regulated

FFIEC, SOX, GLBA, and state privacy laws

Core Assets

Customer PII and financial data



▲ The Problem

60% of employees are using ChatGPT for work tasks with **no oversight**. Goal: Build and roll out an AI risk policy in **30 days**.

This example will make every section of the policy concrete and actionable.



The Starting Point: Discovery

Before writing a single rule, Northwind conducted a discovery phase to understand actual AI usage. Survey results revealed **14 different AI tools** in use across departments.

Marketing

ChatGPT for copywriting and campaign ideas

IT / Engineering

GitHub Copilot for code suggestions

HR

Three different AI resume screeners with none formally approved

Finance 🚨

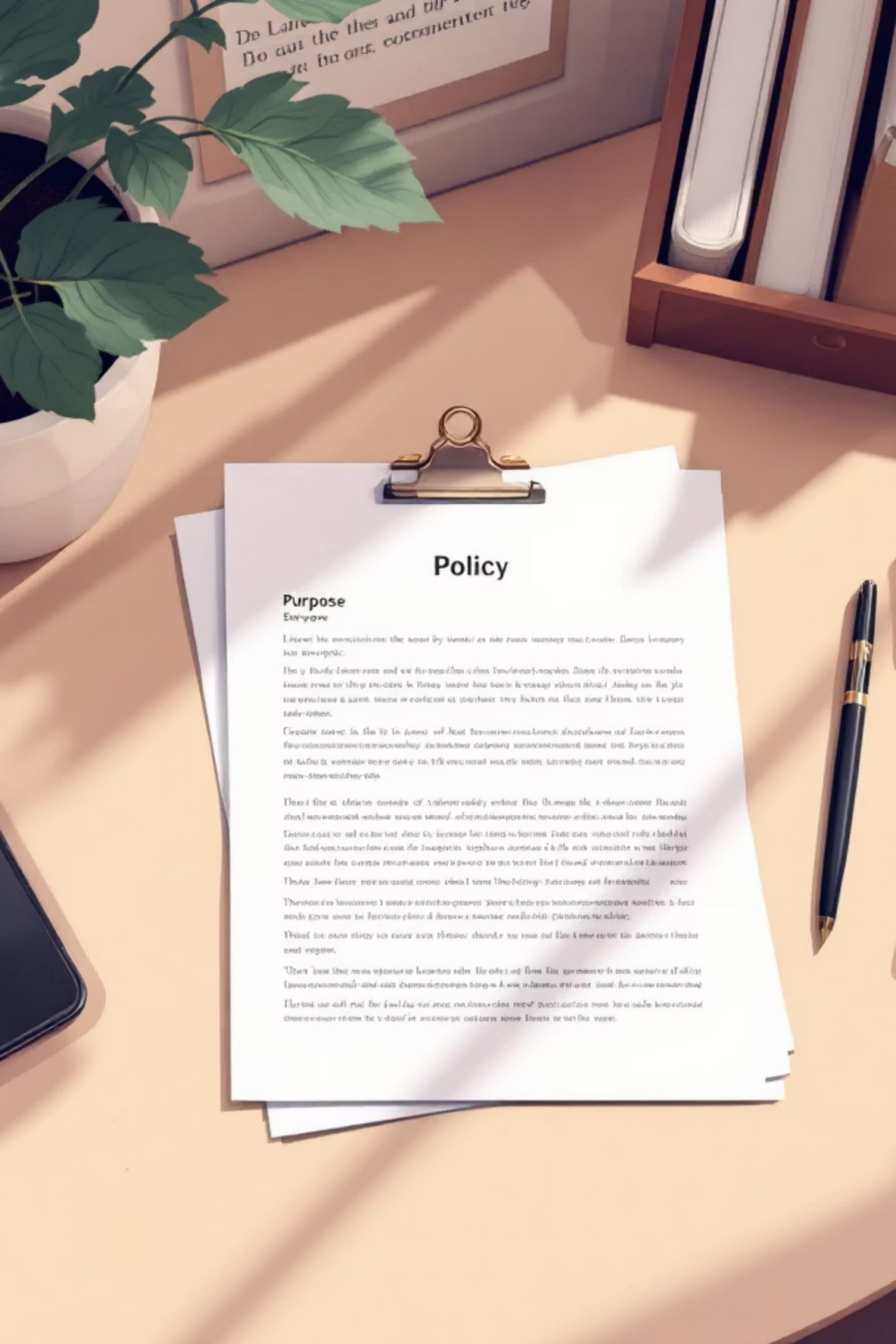
ChatGPT being used to summarize **confidential financial data** — major red flag

Customer Service

An AI chatbot vendor with unclear data handling practices

📌 **Key lesson:** You cannot govern what you do not know exists. Discovery is always step one.





Building Section 1: Purpose & Scope

The first sections set the foundation for everything else.

"To protect customer data, ensure regulatory compliance with FFIEC and GLBA, and enable safe, responsible AI adoption that supports our mission as a trusted regional bank."

Scope Includes

- All employees, contractors, and third-party staff
- All AI tools — cloud-based, embedded, or internally developed
- Customer-facing and internal AI use cases
- AI features built into existing software (e.g., Microsoft Copilot, Salesforce Einstein)



Pro Tip

Be explicit about what is in scope. If it is not listed, assume it will be missed.



Building Section 2: Definitions

Definitions matter but do not over-define. Start with essentials. Northwind chose **6 core definitions**.



AI

Machine-based systems that make predictions, recommendations, or decisions



GenAI

AI that generates new content — text, code, images



LLM

Large Language Models like ChatGPT, Claude, Gemini



Shadow AI

Unauthorized AI tools used by employees without approval



AI System Owner

The accountable person for each AI deployment



High-Risk AI

Systems with significant potential for harm requiring enhanced controls



Pro tip: Adopt definitions directly from NIST AI RMF or the EU AI Act for credibility and consistency.



Building Section 3: Roles & Responsibilities

Northwind did not have a Chief AI Officer and they did not need one. Their solution: Assign AI governance duties to existing roles.

→ CISO

Overall AI governance and security risk

→ DPO

Privacy assessments and DPIAs

→ Legal

Vendor contracts and regulatory compliance

→ CIO

Technology strategy and approved tools list

→ Business Unit Reps

First line of defense within their teams

New AI Governance Committee

Members: CISO, DPO, Legal, CIO, plus 2 business representatives

Cadence: Monthly meetings

Responsibilities: Reviews high-risk AI deployments, approves new tools, resolves escalations



Real-world tip: Do not create a new C-suite role unless you absolutely must. Use existing structures first.



Building Section 4: Approved AI Tools List

Northwind's approved tools. We start small and expand carefully through formal review.

Tool	Approved For	Data Classification	Notes
Microsoft 365 Copilot Enterprise	Drafting, summarizing, productivity	Public, Internal	Enterprise tier with DPA
ChatGPT Enterprise	Research, ideation, drafting	Public, Internal	No customer data permitted
GitHub Copilot Business	Code completion only	Internal code	Proprietary algorithms excluded
Northwind Internal LLM	Customer data analysis	Confidential	On-premise deployment only

 **Critical principle:** Any AI tool not on this list requires formal approval from the AI Governance Committee before use.



Building Section 5: Prohibited Uses

Northwind's **6 hard-line prohibitions** — these are non-negotiable. Each prohibition was tied to a specific regulatory or business risk. Specificity makes the policy enforceable.

No Customer Data in Cloud AI

No customer financial data in any cloud-based AI tool

No Automated Loan Decisions

No AI-generated loan or credit decisions without mandatory human review

No Deepfakes

No synthetic media impersonating any individual, for any purpose

No Underground LLMs

No use of WormGPT, FraudGPT, or similar dark AI tools

No Security Bypass

No use of AI to bypass security controls, authentication, or access restrictions

No Unauthorized Training Data

No use of copyrighted material as AI training data without legal authorization



Building Section 6: Data Classification Rules

Northwind mapped their existing **5-tier data classification scheme** directly to AI usage rules.

	Customer PII / Financial Requires DPO sign-off plus a completed DPIA before any AI processing
	Restricted On-premise or private cloud AI only — no external services
	Confidential Restricted approved tools only with usage logged and audited
	Internal Enterprise-grade approved tools only and must have DPA in place
	Public Any approved AI tool may be used with no restrictions

 **Key insight:** Do not create a new classification scheme for AI. Reuse what your organization already has — employees already understand it.



Building Section 7: AI Risk Assessment Process

A 6-step process applied to a real Northwind example. **Scenario:** HR wants to deploy "RecruitAI" for automated resume screening.

- 1

Inventory
Document the system — vendor, purpose, data flows, stakeholders
- 2

Classify
HIGH RISK — affects employment decisions and processes PII
- 3

Assess
Identified bias risk in training data, lack of explainability, GDPR concerns
- 4

Treat
Conditional approval — mandatory human review of all rejections, quarterly bias audits, candidate disclosure required
- 5

Document
Recorded in AI Risk Register with full assessment trail
- 6

Monitor
Quarterly bias testing, model drift monitoring, ongoing compliance review

This same process applies to every new AI system whether it is internal or vendor-provided.



Building Section 8: Incident Reporting

Northwind established a **4-hour incident reporting window** which is aggressive but necessary.

Reporting Channel

`ai-incidents@northwind.com` → routed to CISO and DPO immediately

Trigger Examples

- Confidential or customer data accidentally submitted to a public AI tool
- Biased or harmful AI output discovered in production
- Unauthorized AI tool detected on the corporate network
- AI vendor breach notification received
- Regulatory inquiry related to AI decision-making

4-Hour Window

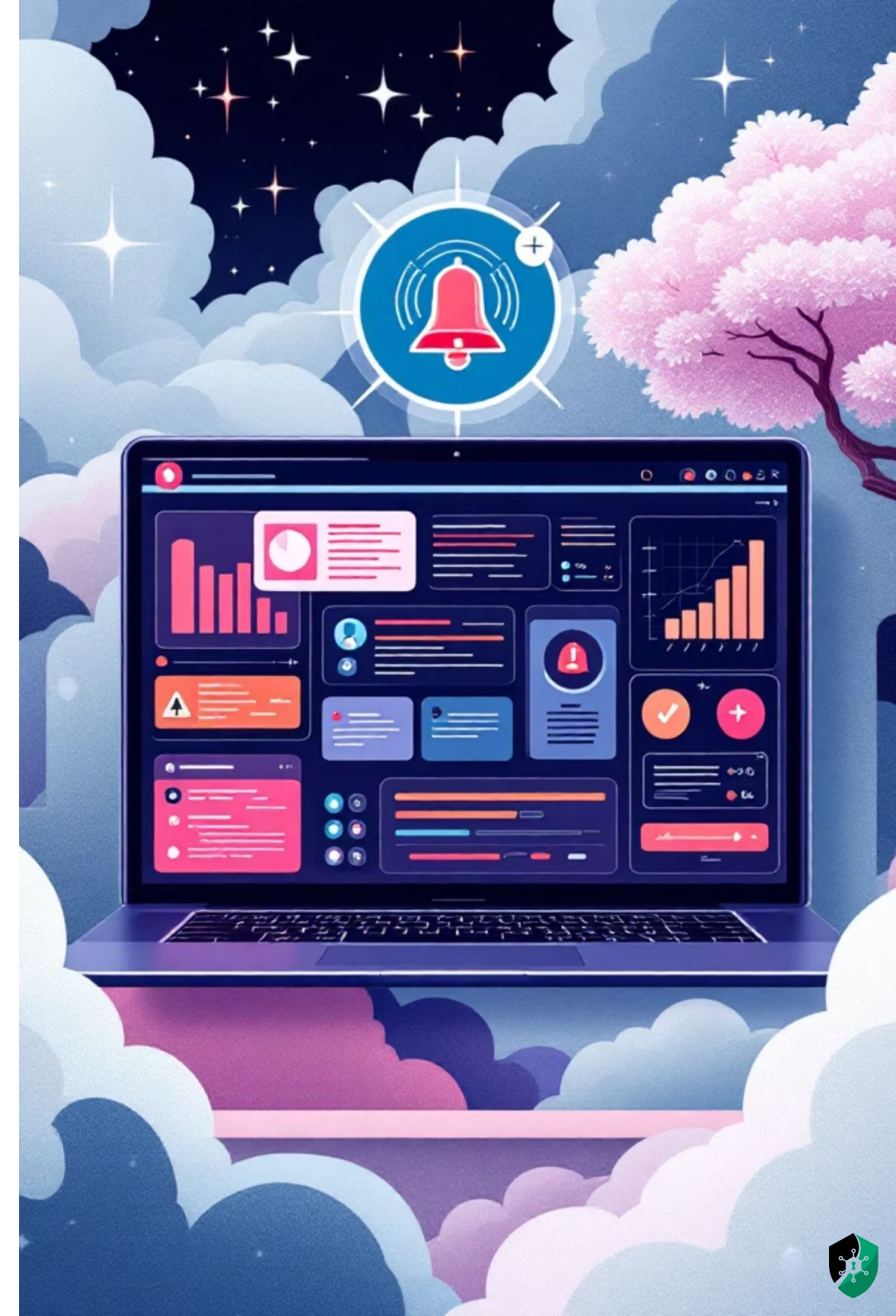
Mandatory reporting deadline from discovery

AI Playbook

AI-specific triage, containment, and notification procedures

Existing IRP

Follows the existing incident response plan — no reinvention needed



Common Pitfalls Northwind

Avoided

Lessons learned from organizations that got AI governance wrong.

-  **Banning AI Entirely**
Northwind chose to enable and govern instead of banning which would have driven shadow AI deeper underground
-  **Copying a Generic Policy**
They customized every section to their banking context and regulatory environment
-  **Forgetting Embedded AI**
They specifically inventoried Salesforce Einstein, Outlook Copilot, and other embedded features
-  **No Executive Sponsorship**
The CEO personally endorsed the policy at the all-hands meeting and gave it organizational weight
-  **Treating It as a One-Time Project**
Established the policy as an ongoing program with quarterly reviews and continuous monitoring



The 30-Day Implementation Timeline

Northwind's actual rollout schedule which is a realistic, achievable timeline.

1

Week 1

Discovery Phase — Survey employees, inventory tools, conduct stakeholder interviews

2

Week 2

Draft Policy — Write all sections, internal review with legal and compliance teams

3

Week 3

Executive Review — Present to AI Governance Committee, secure CEO endorsement

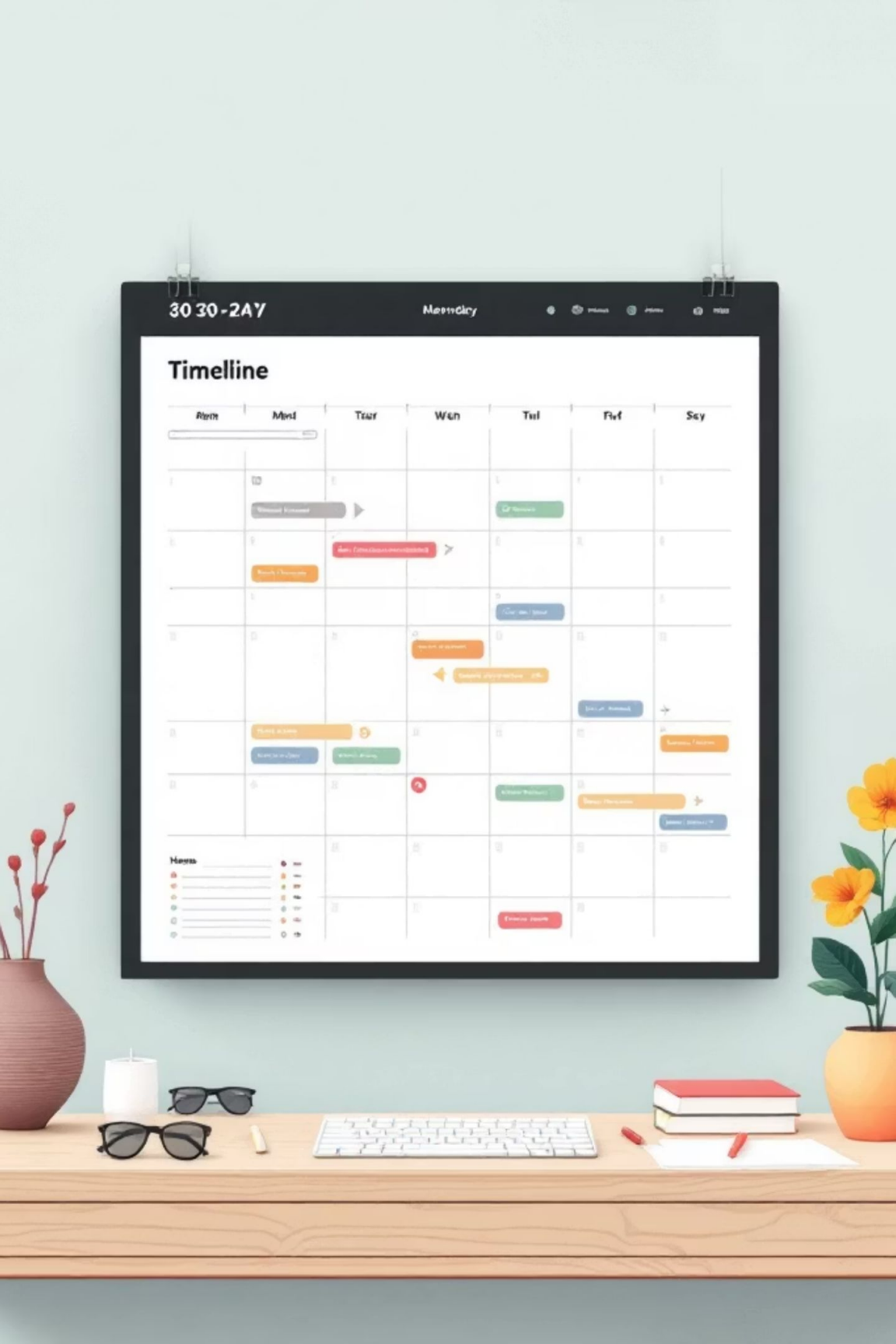
4

Week 4

Rollout — Communicate to all staff, deploy mandatory training, policy goes live



30 days is aggressive but doable for a mid-size organization with strong sponsorship. Larger or more complex organizations may need **60–90 days**.



Your Turn: Workshop

Now apply what you have learned. Build your own draft AI risk policy. **Time required:** Approximately 2–3 hours for a meaningful first draft.

- 1

Pick an Organization

Pick an organization or create a fictional one
- 2

Download the Template

Download the AI Risk Policy Template provided in this section
- 3

Complete Sections 1–5

Purpose, Scope, Definitions, Roles, and Approved Tools
- 4

Identify 5 Prohibitions

Identify 5 prohibited AI uses specific to your industry
- 5

Map Data Classification

Map your existing data classification scheme to AI usage rules
- 6

Peer Review

Bring your draft to the next session for peer review and discussion



Key Takeaways



Start with Discovery

Find your shadow AI before writing any rules



Use a Concrete Example

Abstract policies fail but real or fictional examples make them stick



Customize, Don't Copy

Your industry, regulations, and culture matter



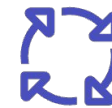
Get Executive Sponsorship

Without it from day one, the policy will fail



Templates Accelerate Work

Use the AI Risk Policy Template provided in this section



Governance is Ongoing

Version 1.0 is better than perfection that never ships so always iterate and improve

❏ **Remember:** 30 days is enough for a strong first version with focused effort and executive support. Iterate and improve and remember that governance is a program, not a project.

